Poking the S in SD cards

Nicolas Oberli

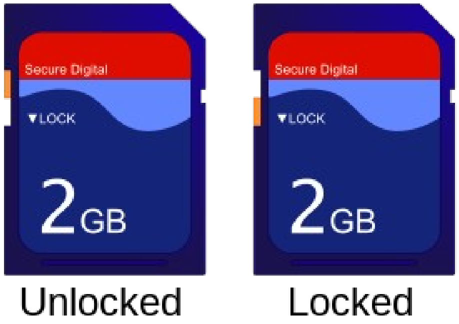
KUDELSKI SECURITY

Introduction

- SD stands for *Secure Digital*
  - What is the *Secure* for ?
- No physical attacks on the cards

What is an SD card ?

- Basically a microcontroller interfacing the SD interface with flash memory
- See bunnie and xobs talk @ 30C3 for details



https://en.wikipedia.org/wiki/SD_card

Communication

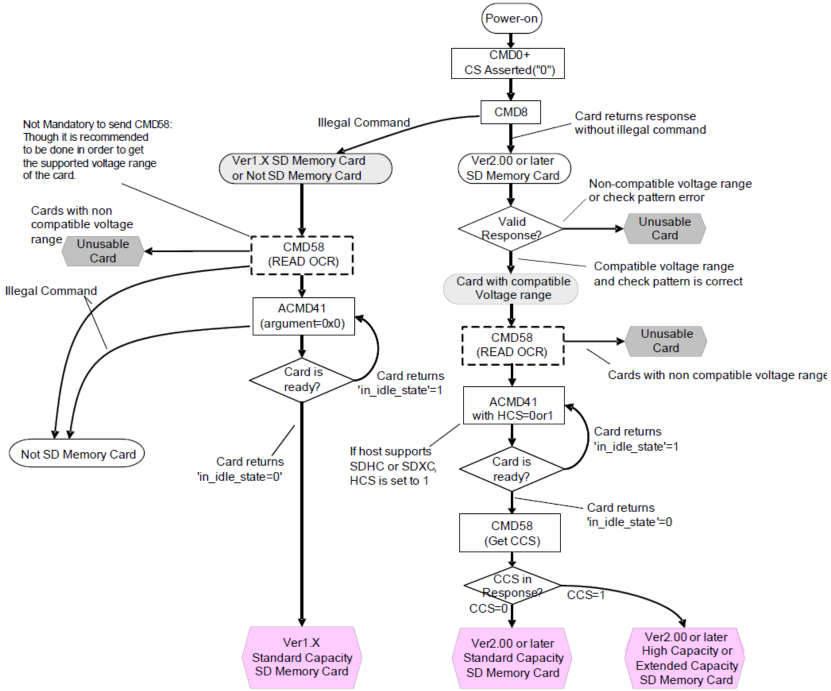
- SD cards support 3 communication protocols
  - SPI Bus protocol
    - Classic SPI
  - SD / UHS-I Bus protocol
    - CLK, CMD, Up to 4 data lines
  - UHS-II Bus protocol
    - RCLK, 2 differential data lines

https://en.wikipedia.org/wiki/SD_card

Time to dig into the specs

- Specs are freely available in a simplified format on the SD association website
  - 262-pages document (general specs – part 1)
  - Presents the general description of the SD System

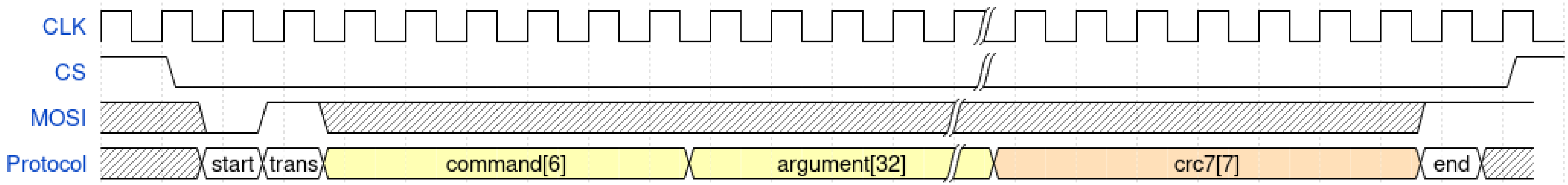
Initialization sequence



SD specs part 1, figure 7-2

Protocol

- Query/reply-based
- Each command has a number and is usualy referenced with it
  - eg. CMD0 - GO_IDLE_STATE



Protocol – cont.

- 7 different response formats
  - Depends on the command
- Protocol implements a block transfer feature
  - Used to transfer more than 4 bytes
  - Block starts with *0xFE*
  - Length is defined by CMD16 (512 bytes by default)

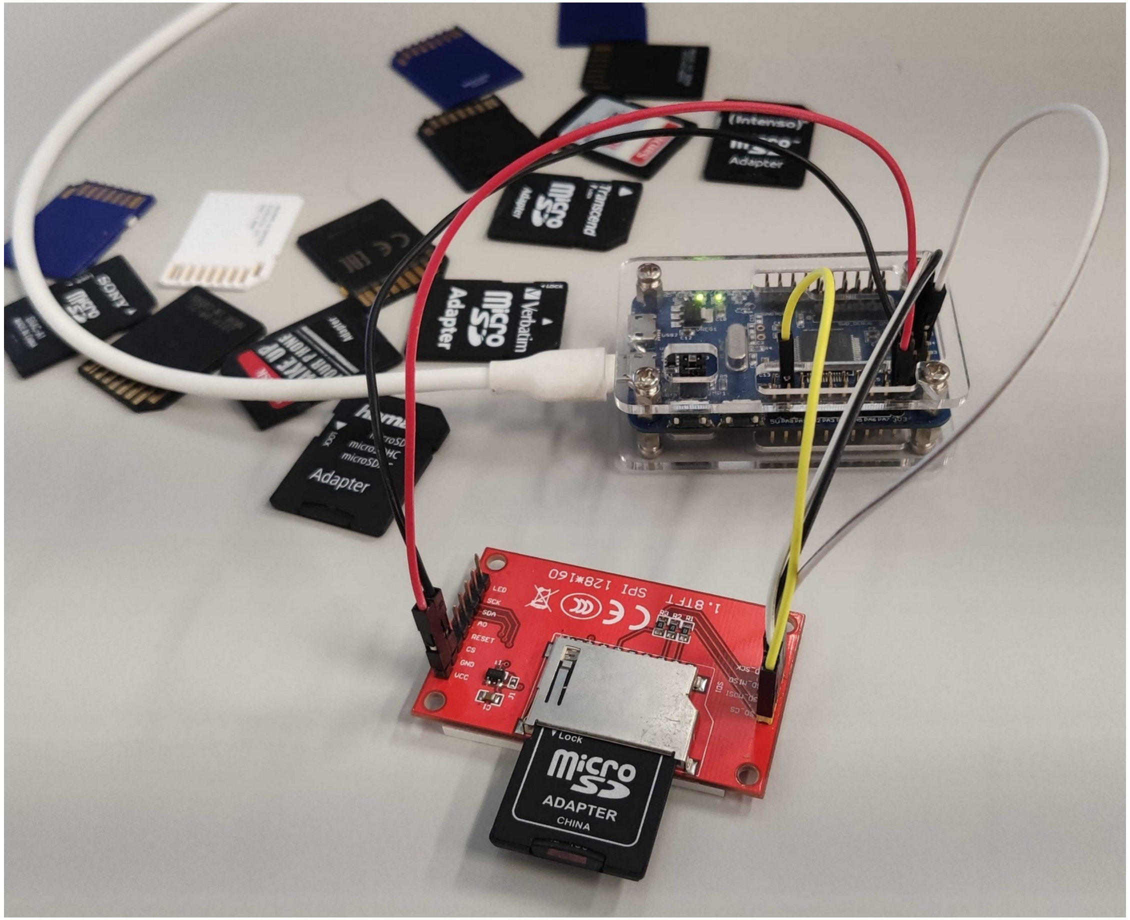
Security features

- SDMI – Secure Digital Music Initiative
  - Detailed under specs part 3
    - Available only to SD members / NDA
  - Not covered here
- Can be read- and/or write-protected
  - Available through CMD27 and CMD42
  - These commands are **mandatory** to get SD label

Interfacing with SD card

- First need to communicate correctly with the card
- Implemented a Python script to drive the SPI interface and access the SD card using raw commands
- CRC is optional in SPI mode, easier to play with

Setup

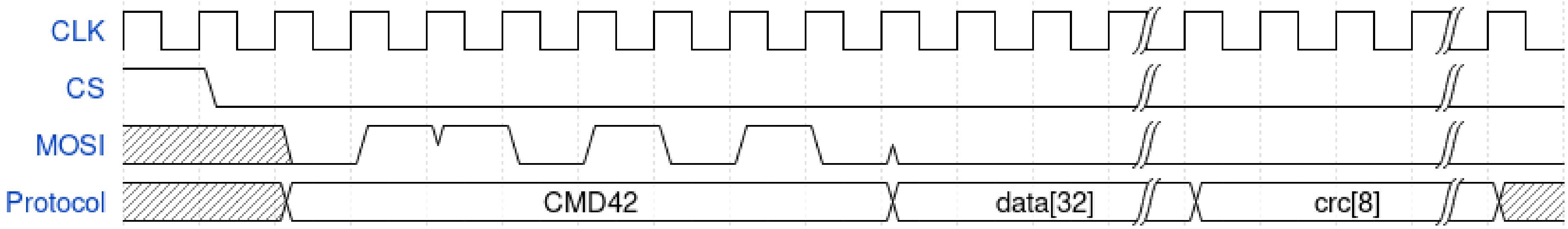

1.8TFT SPI 128*160
LED
SCK
SDA
A0
RESET
CS
GND
VCC
Lock
micro SD
ADAPTER
CHINA
Verbatim
Adapter
Transcend
Intenso
Adapter

CMD42 – LOCK_UNLOCK

- Used to control the password protection mechanism
  - Up to 16 bytes
  - Not limited to printable characters
  - Keyspace : 2^{128} – Same as an AES key
    - Bruteforce is unachievable

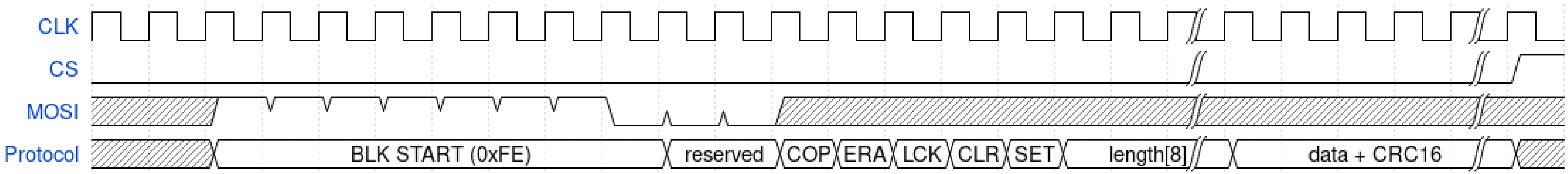
Locking the SD card

- The *CMD42* command controls the password locking functions
  - Takes no parameter, but card expects a following data block



CMD42 data block

- Contains the command options, length and the actual password



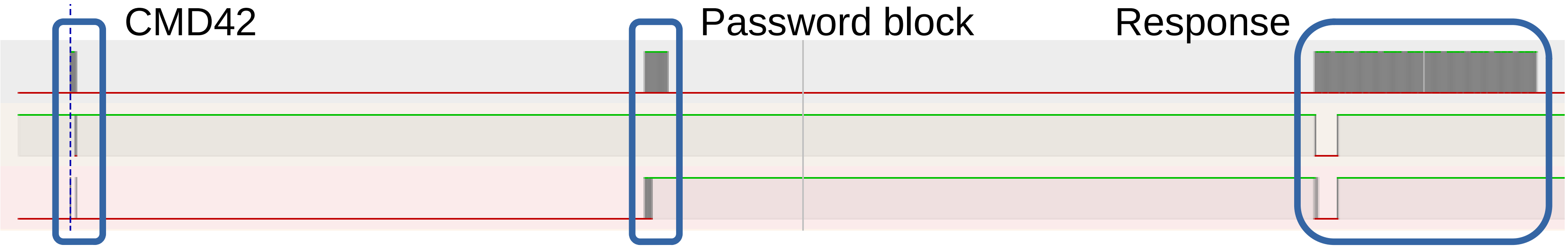
Unlocking SD card

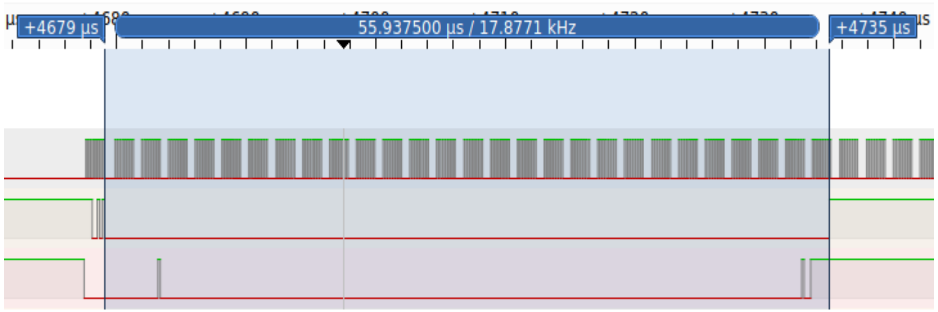
- Send *CMD42*
- Send a data block, unsetting the *LOCK* bit, setting the password length and the password
- Card will assert the MISO line, then send an ACK once the command has been processed
- Lock status is available in the status bits (CMD13)

Unlocking SD card

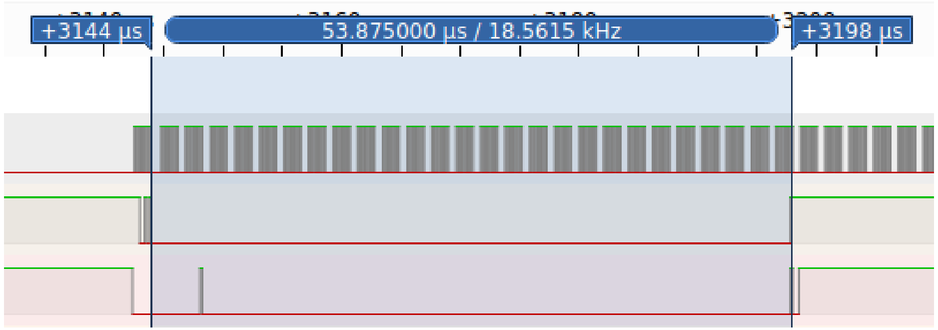
- Send *CMD42*
- Send a data block, unsetting the *LOCK* bit, setting the password length and the password
- **Card will assert the MISO line, then** send an ACK once the command has been processed
- Lock status is available in the status bits (CMD13)

Guess what happens ?





00000



000000

What’s happening ?

- SD controller checks for the length of the password, then compares each byte to the correct password
- Returns an error as soon as there’s a discrepancy
- Possible to determine a correct byte by measuring processing time

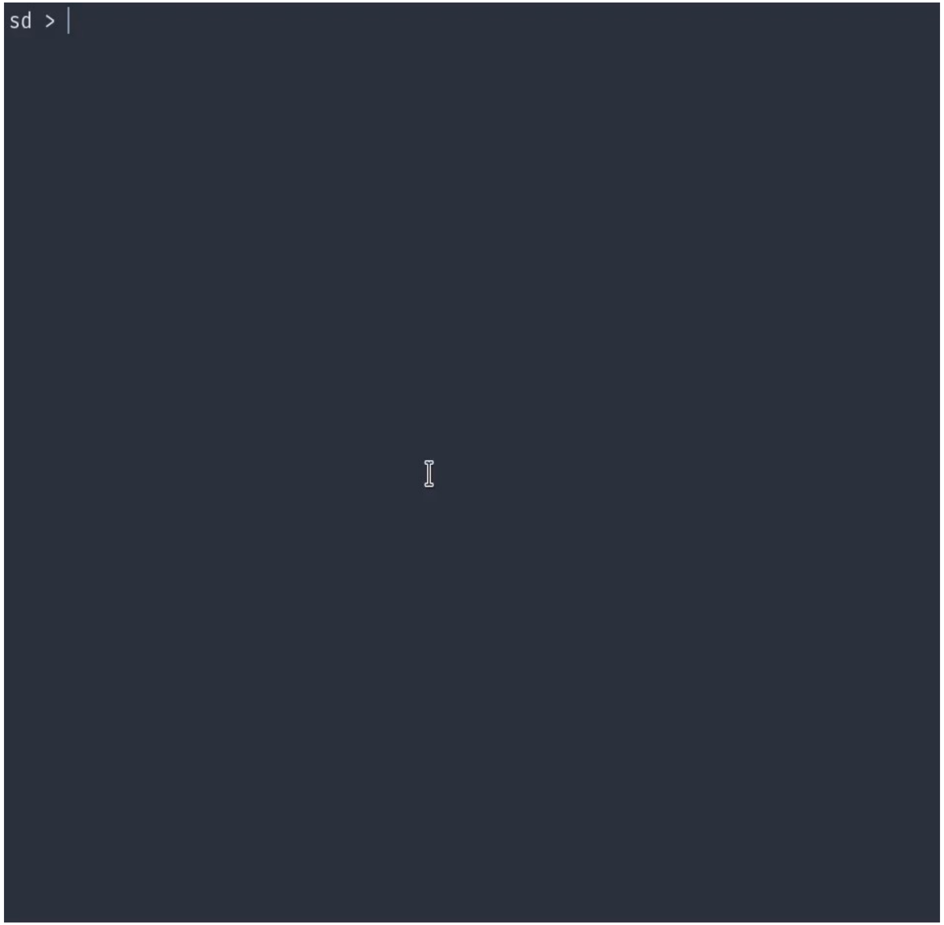
Measuring time using SPI

- During processing time, read dummy bytes as fast as possible
- As long as we read zeroes, the password check is still ongoing
- Once we read a 1, count the number of zeroes

In practice :

```
sd > test_len
  00 : 122
  01 : 124
  02 : 124
  03 : 124
  04 : 124
  05 : 124
* 06 : 130
  07 : 124
  08 : 124
  09 : 124
  10 : 124
  11 : 124
  12 : 124
  13 : 124
  14 : 124
  15 : 124
  16 : 124
Length: 6
sd >
```

DEMO



So ?

- Bought a bunch of SD cards (~20)
  - Different vendors
  - Different sizes
- Also asked colleagues / friends for SD cards
  - The only card I permanently locked was not mine (‘-’*)
- Locked them with “123456” as password

Special cases – Sony SD

- Card refuses to check for the password after three failed attempts
- Need to remove and insert the card again to get 3 more attempts
  - In fact, doing a reset sequence (CMD0) is enough to get 3 more tries
  - Slightly makes the bruteforce slower

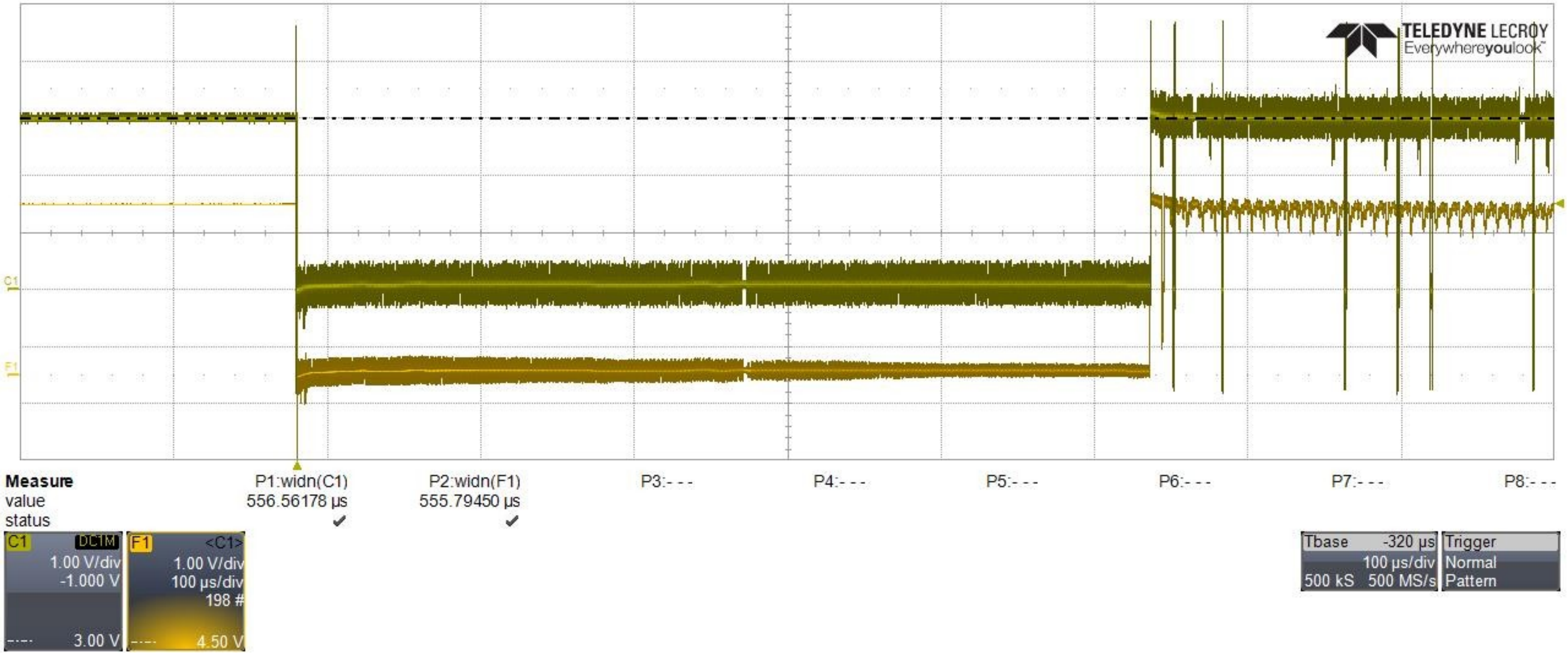
Special cases – Sony uSD

- Card seems to have a really fast checking time
  - Can get no or maybe one zero bit
- Our sampling rate might be too slow
  - SPI interface is ~42MHz
  - Using logic analyzer (100MSPS) still does not show any usable results

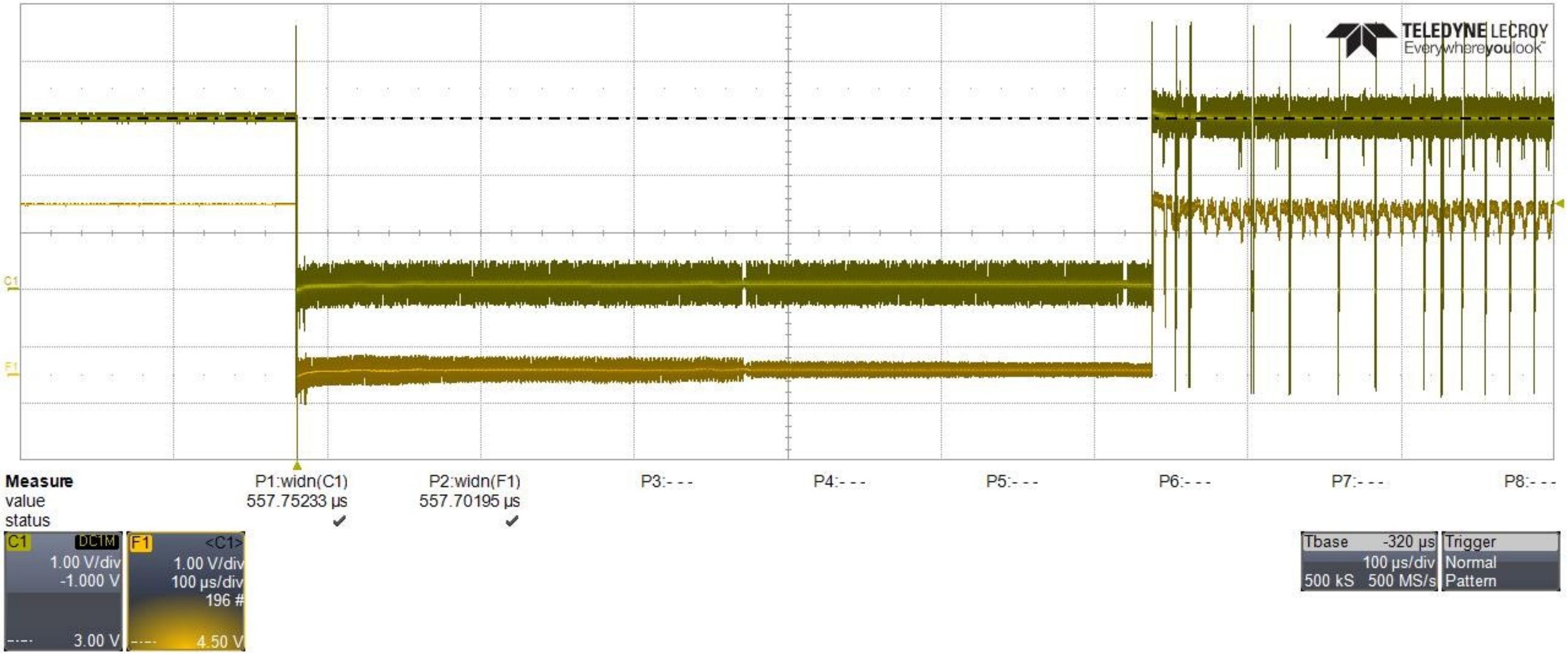
Faster !!

- Used lab oscilloscope
  - Up to 40GSPS, more than enough
- Had to setup a trigger for correct measurement

And...


TELEDYNE LECROY
Everywhereyoulook
C1
F1
Measure
value
status
P1:widn(C1)
556.56178 µs
P2:widn(F1)
555.79450 µs
P3:- - -
P4:- - -
P5:- - -
P6:- - -
P7:- - -
P8:- - -
C1 DC1M
1.00 V/div
-1.000 V
3.00 V
F1 <C1>
1.00 V/div
100 µs/div
198 #
4.50 V
Tbase -320 µs
100 µs/div
500 kS 500 MS/s
Trigger
Normal
Pattern

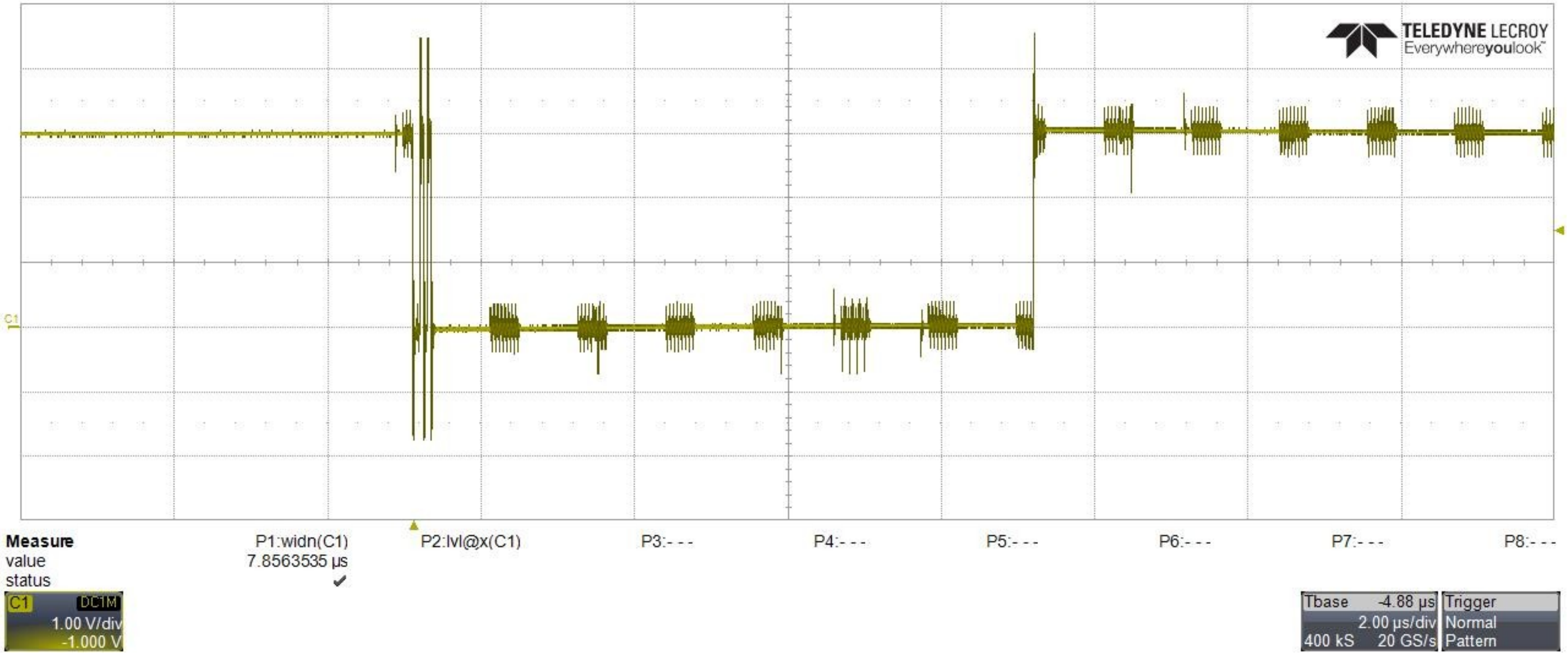
And…


TELEDYNE LECROY
Everywhereyoulook
C1
F1
Measure
value
status
P1:widn(C1)
557.75233 µs
P2:widn(F1)
557.70195 µs
P3:- - -
P4:- - -
P5:- - -
P6:- - -
P7:- - -
P8:- - -
C1 DC1M
1.00 V/div
-1.000 V
3.00 V
F1 <C1>
1.00 V/div
100 µs/div
196 #
4.50 V
Tbase -320 µs
100 µs/div
500 kS 500 MS/s
Trigger
Normal
Pattern

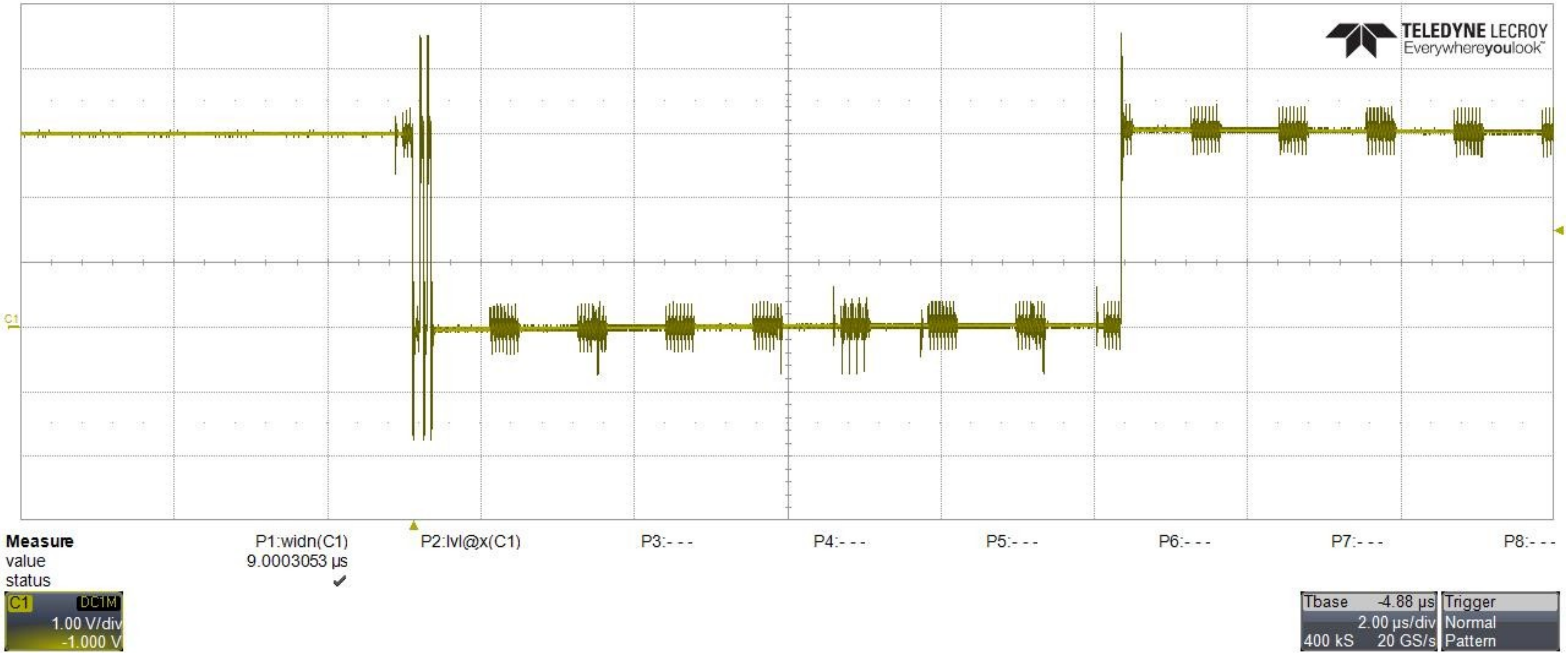
Special cases - Kingston

- It is possible to count the password length, but not the password chars
- Took a lot of measurements until I found this :

00000

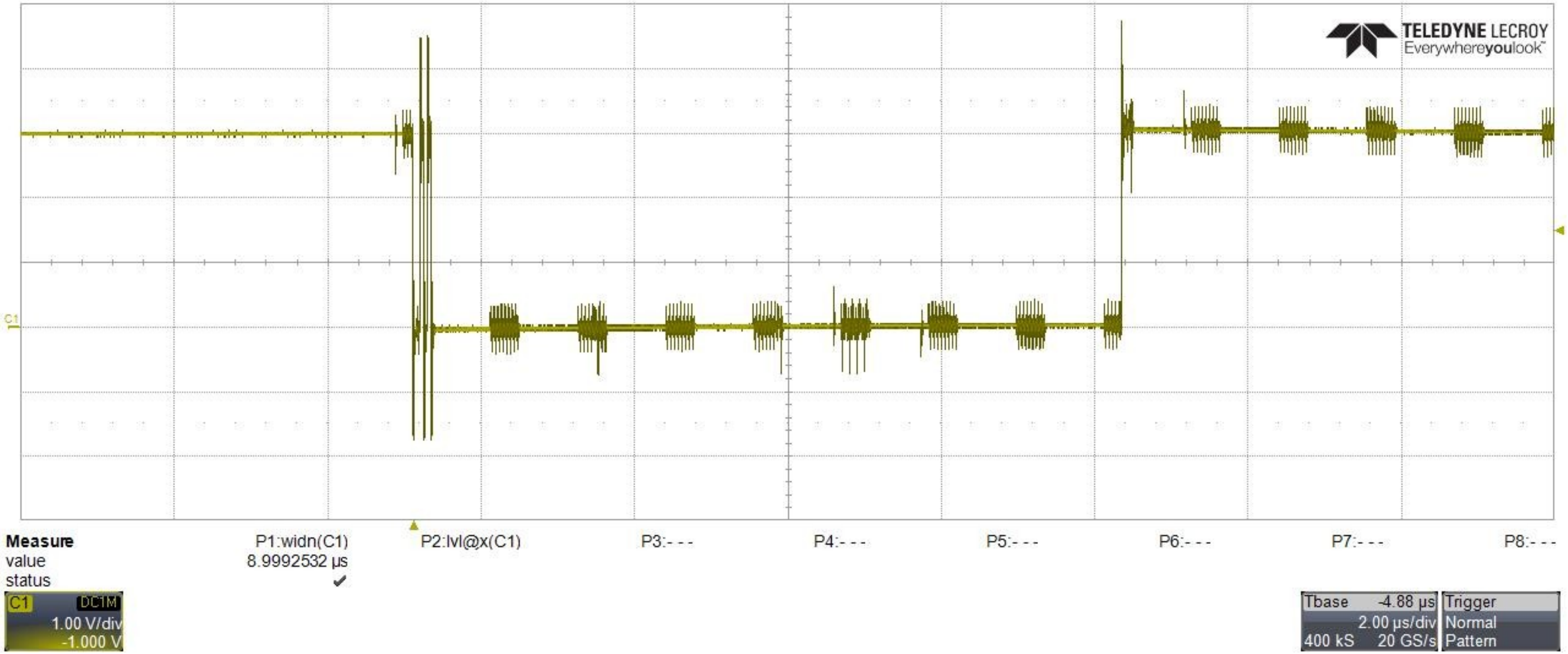

TELEDYNE LECROY
Everywhereyoulook
C1
Measure
value
status
P1:widn(C1)
7.8563535 µs
P2:lvl@x(C1)
P3:- - -
P4:- - -
P5:- - -
P6:- - -
P7:- - -
P8:- - -
C1 DC1M
1.00 V/div
-1.000 V
Tbase -4.88 µs
2.00 µs/div
400 kS 20 GS/s
Trigger
Normal
Pattern

000000



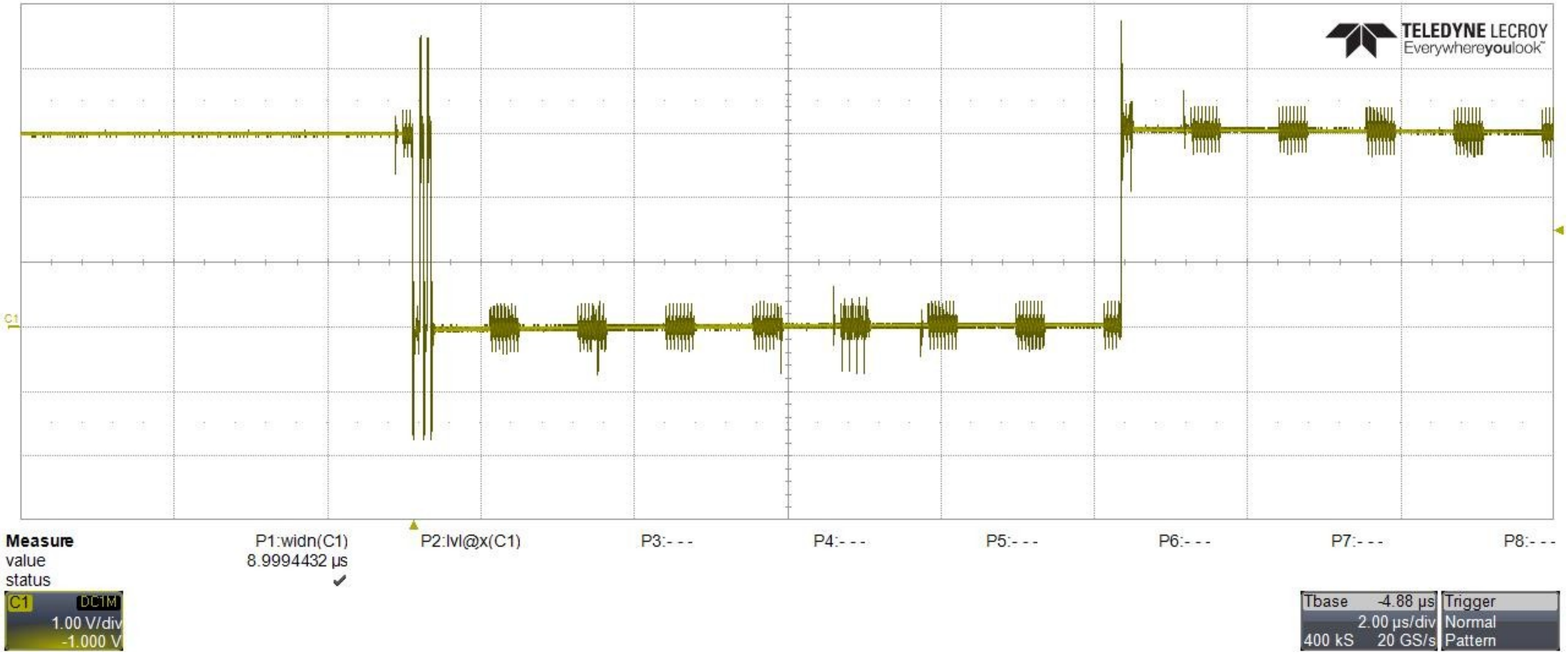
TELEDYNE LECROY
Everywhereyoulook
C1
Measure
value
status
P1:widn(C1)
9.0003053 µs
P2:lvl@x(C1)
P3:- - -
P4:- - -
P5:- - -
P6:- - -
P7:- - -
P8:- - -
C1
DC1M
1.00 V/div
-1.000 V
Tbase -4.88 µs
2.00 µs/div
400 kS 20 GS/s
Trigger
Normal
Pattern

100000

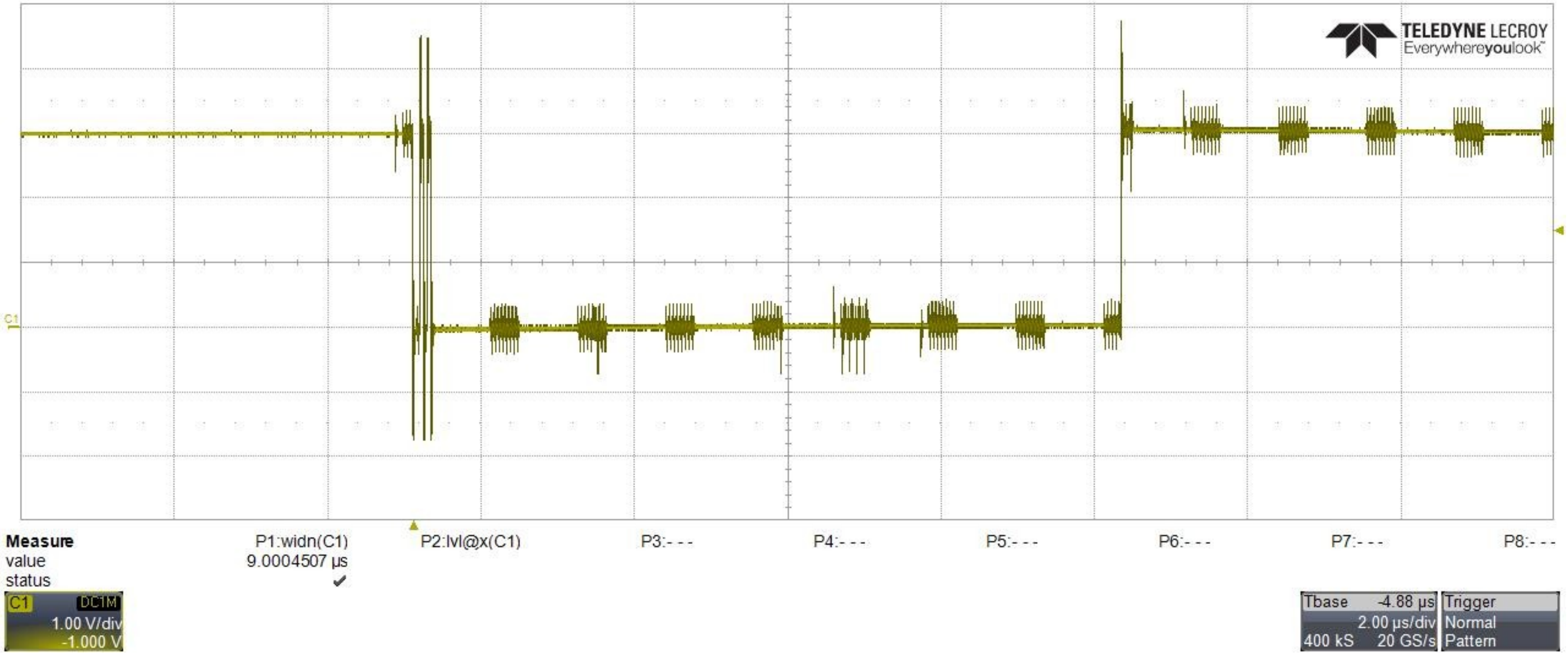


TELEDYNE LECROY
Everywhereyoulook
C1
Measure
value
status
P1:widn(C1)
8.9992532 µs
P2:lvl@x(C1)
P3:- - -
P4:- - -
P5:- - -
P6:- - -
P7:- - -
P8:- - -
C1
DC1M
1.00 V/div
-1.000 V
Tbase
-4.88 µs
2.00 µs/div
400 kS
20 GS/s
Trigger
Normal
Pattern

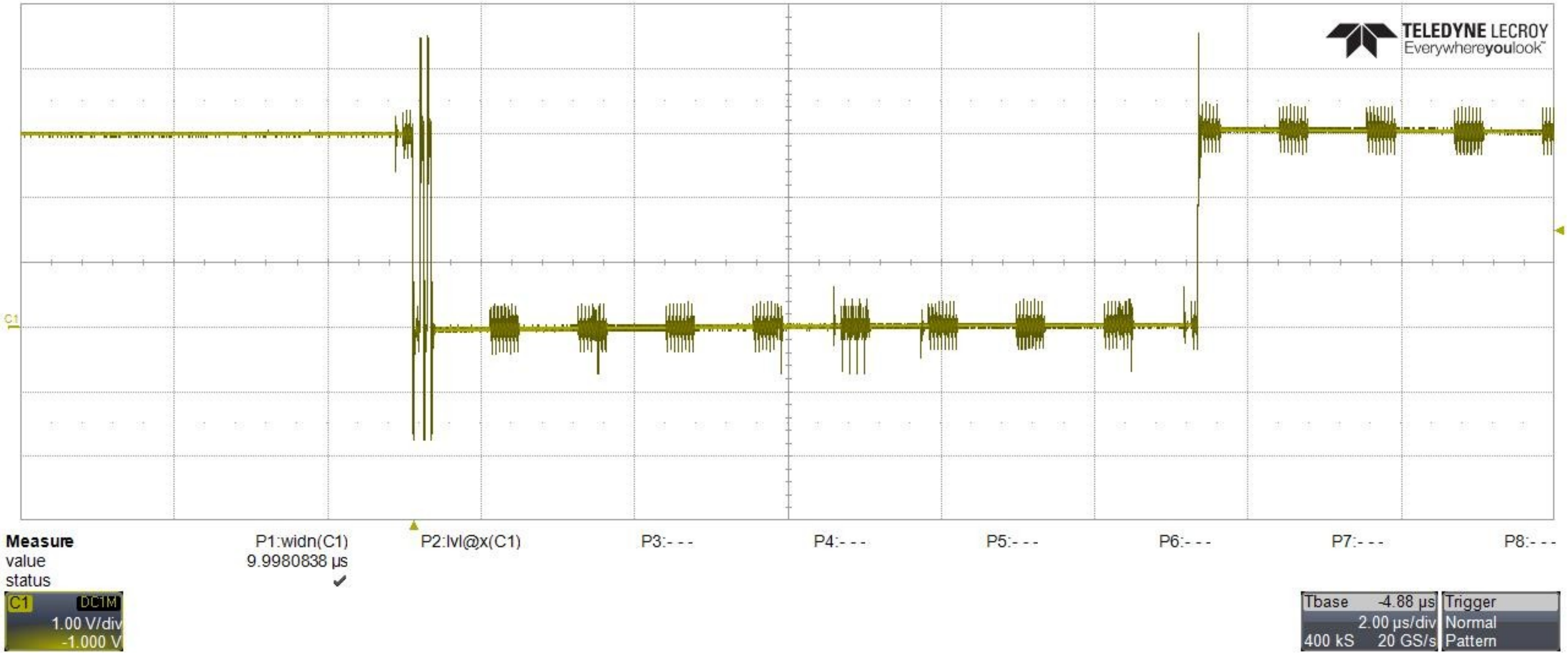
120000


TELEDYNE LECROY
Everywhereyoulook
C1
Measure
value
status
P1:widn(C1)
8.9994432 µs
P2:lvl@x(C1)
P3:- - -
P4:- - -
P5:- - -
P6:- - -
P7:- - -
P8:- - -
C1
DC1M
1.00 V/div
-1.000 V
Tbase -4.88 µs
2.00 µs/div
400 kS 20 GS/s
Trigger
Normal
Pattern

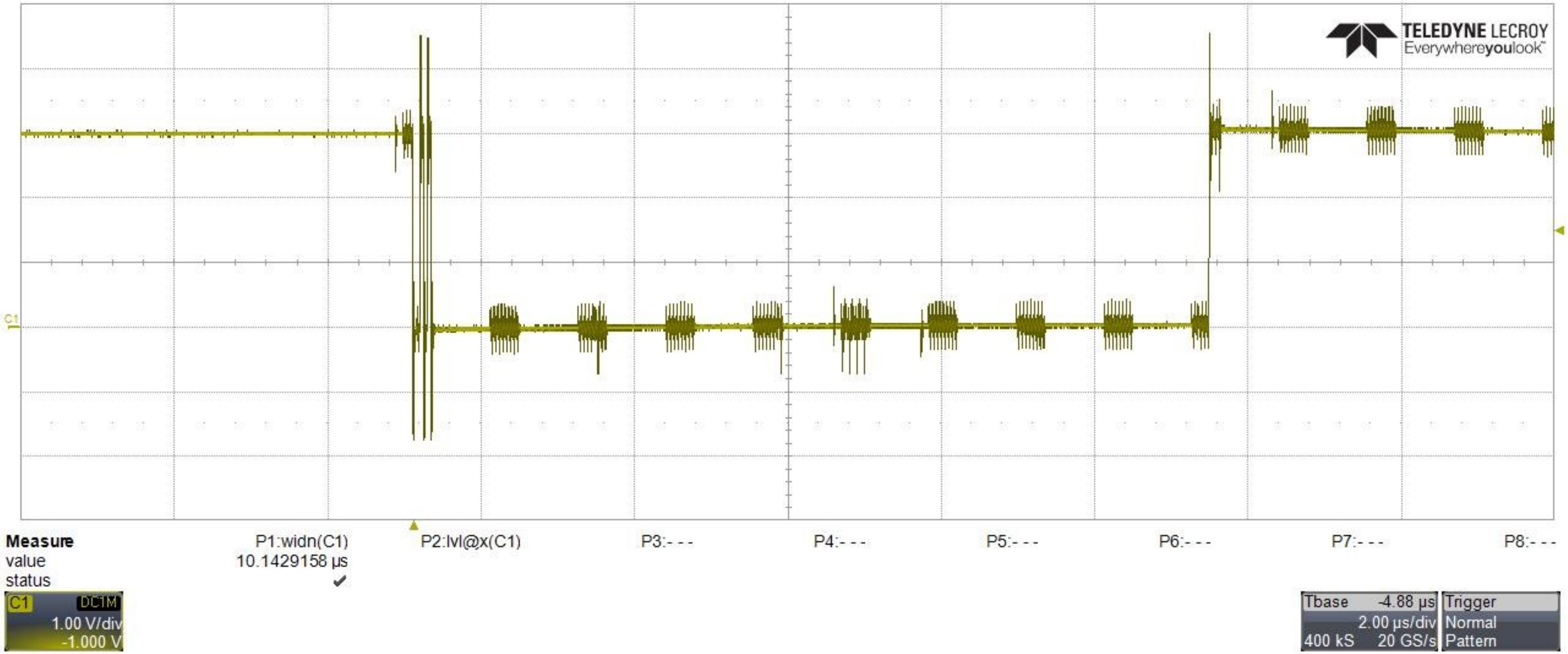
123000


TELEDYNE LECROY
Everywhereyoulook
C1
Measure
value
status
P1:widn(C1)
9.0004507 µs
P2:lvl@x(C1)
P3:- - -
P4:- - -
P5:- - -
P6:- - -
P7:- - -
P8:- - -
C1 DC1M
1.00 V/div
-1.000 V
Tbase -4.88 µs
2.00 µs/div
400 kS 20 GS/s
Trigger
Normal
Pattern

123400


TELEDYNE LECROY
Everywhereyoulook
C1
Measure
value
status
P1:widn(C1)
9.9980838 µs
P2:lvl@x(C1)
P3:- - -
P4:- - -
P5:- - -
P6:- - -
P7:- - -
P8:- - -
C1
DC1M
1.00 V/div
-1.000 V
Tbase
-4.88 µs
2.00 µs/div
400 kS
20 GS/s
Trigger
Normal
Pattern

123450


TELEDYNE LECROY
Everywhereyoulook
C1
Measure
value
status
P1:widn(C1)
10.1429158 µs
P2:lvl@x(C1)
P3:- - -
P4:- - -
P5:- - -
P6:- - -
P7:- - -
P8:- - -
C1 DC1M
1.00 V/div
-1.000 V
Tbase -4.88 µs
2.00 µs/div
400 kS 20 GS/s
Trigger
Normal
Pattern

Still vulnerable

- Password checking works on groups of 4 bytes
- If remaining bytes to check is >= 4, test each byte individually
- Attack takes more time, but works anyways ¯_(ツ)_/¯

Results

Card	Manufacturer	Prod. date*	Vulnerable ?
Transcend uSD 4GB	Transcend (0x74)	09/2011	Yes
Transcend uSD 16GB	Transcend (0x74)	10/2012	Yes
Hama 8GB	Phison (0x27)	06/2010	Yes
Maxell 32GB	Phison (0x27)	10/2011	Yes
Sony uSD 32GB	Sony (0x9c)	07/2012	Yes
Sony 32GB	Sony (0x9c)	12/2011	Yes
Kingston uSD 32GB	Unknown (0x9f)	10/2012	Yes
Sandisk Extreme 128GB	Sandisk (0x03)	03/2012	No
Sandisk mobile ultra 16GB	Sandisk (0x03)	12/2009	No
Samsung Evo+ uSD 32GB	Samsung (0x1b)	10/2012	Unsupported

* Production date format is not consistent

Ouch

- Sandisk only controller I tested not vulnerable to this attack
- Remember : SD vendor != Controller manufacturer
- Samsung cards respond with invalid command using CMD42

Conclusions

- Useless vulnerability ?
  - Feature not supported by any OS
- Affects a lot of manufacturers
- Reading specs is fun

Future work

- COP protection
  - Added in specs v5.00
  - Adds a password to protect the clear password feature
  - Couldn’t find a card that supports it

Takeaways

- SD cards have a password protection builtin
  - Not supported by major operating systems
  - Many implementations exist
- This protection is vulnerable to a timing attack on some manufacturer cards

Thank you !

Nicolas Oberli
@baldanos

KUDELSKI SECURITY